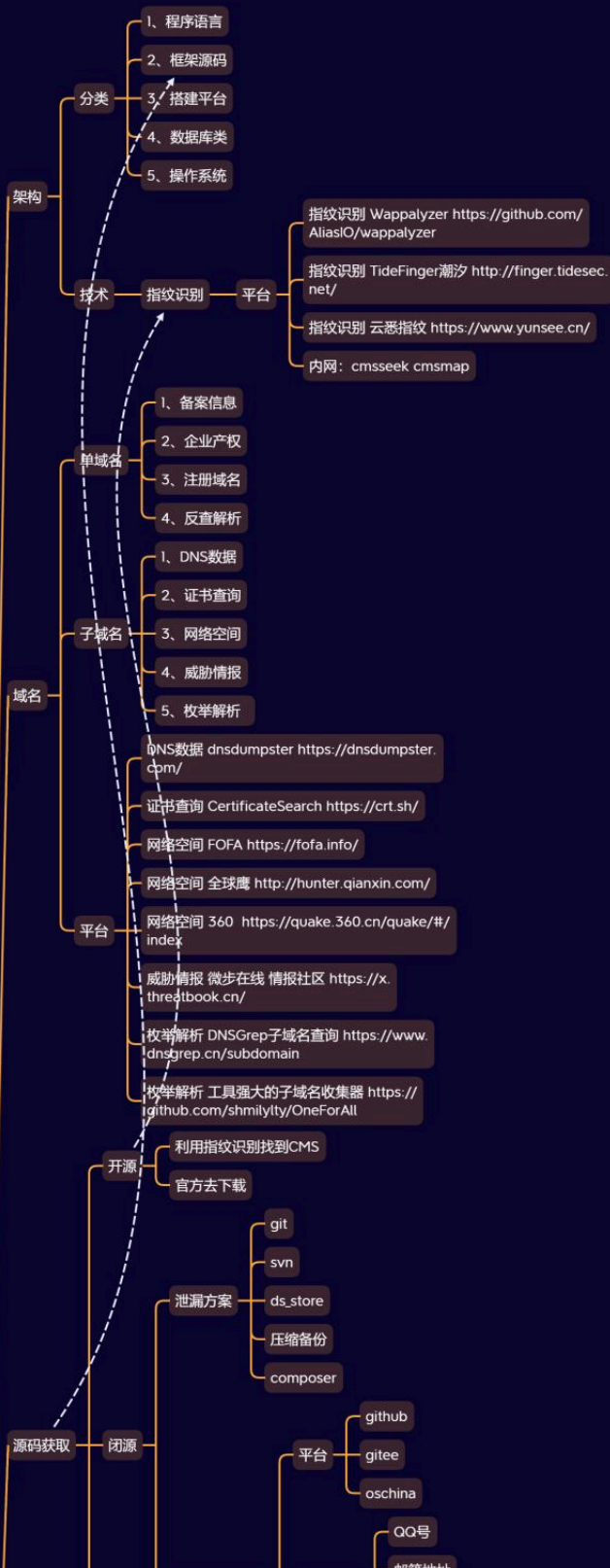


Day19 信息打点-小程序应用&解包反编译&动态调试&抓包&静态分析&源码架构

业务资产

- 查询平台
 - 爱企查
 - 小蓝本
- 业务类型
 - 1. WEB应用
 - 2. APP应用
 - 3. PC端应用
 - 4. 小程序应用
 - 5. 微信公众号
 - 6. 其他产品等



1 Web应用

JS前端架构



人工

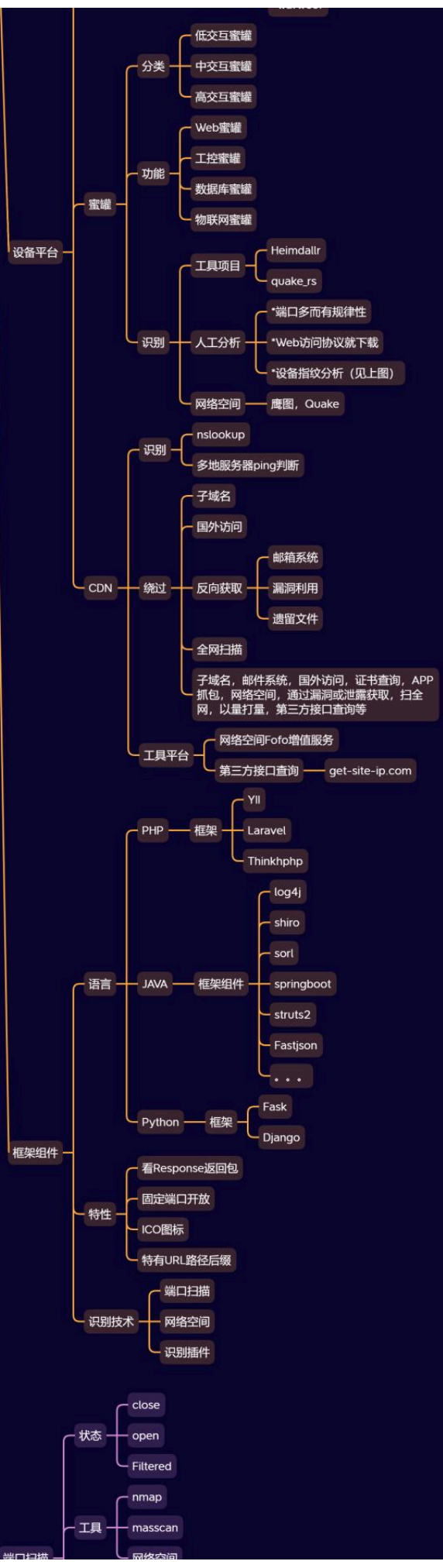


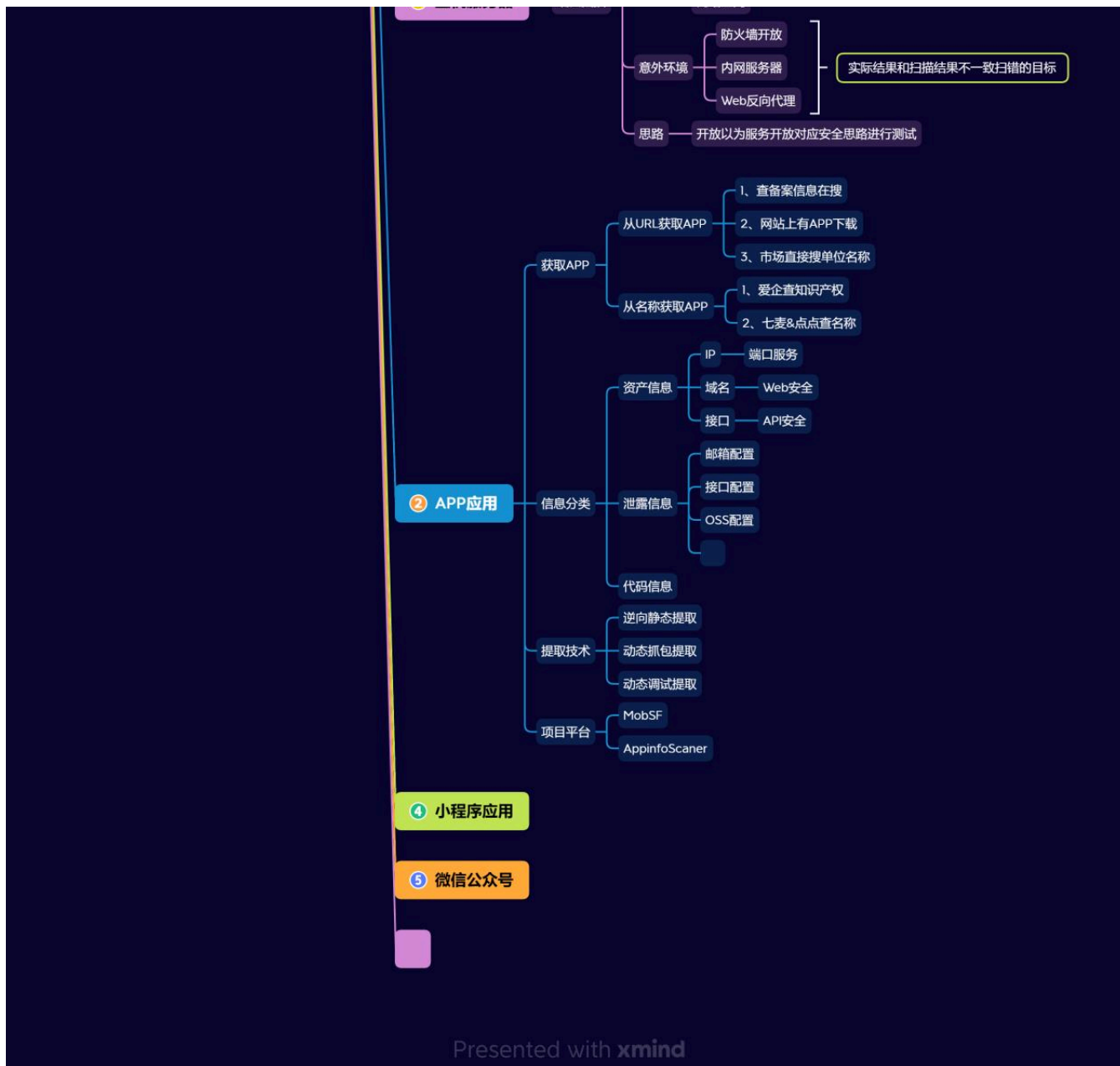
测试方法



WAF







1.知识点

- 1、业务资产-应用类型分类
- 2、Web单域名获取-接口查询
- 3、Web子域名获取-解析枚举
- 4、Web架构资产-平台指纹识别

- 1、开源-CMS指纹识别源码获取方式
- 2、闭源-习惯&配置&特性等获取方式
- 3、闭源-托管资产平台资源搜索监控

- 1、JS前端架构-识别&分析
- 2、JS前端架构-开发框架分析

- 3、JS前端架构-打包器分析
- 4、JS前端架构-提取&FUZZ

解决:

- 1、如何从表现中的JS提取价值信息
- 2、如何从地址中FUZZ提取未知的JS文件
- 3、如何从JS开放框架WebPack进行测试

-
- 1、端口扫描-应用&协议
 - 2、WAF识别-分类&识别
 - 3、蜜罐识别-分类&识别

解决:

- 1、Web服务器&应用服务器差异性
- 2、WAF防火墙&安全防护&识别技术
- 3、蜜罐平台&安全防护&识别技术

-
- 1、CDN 服务-解释差异识别
 - 2、CDN 绕过-配置差异导致
 - 3、CDN 绕过-主动连接获取
 - 4、CDN 绕过-全网扫描获取

解决:

- 1、CDN 服务对安全影响
- 2、CDN 服务绕过识别手法

-
- 1、CMS指纹识别-不出网程序识别

- 2、开发框架识别-PHP&Python&Java
- 3、开发组件识别-Java常见安全漏洞组件

解决:

- 1、CMS识别到后期漏洞利用和代码审计
- 2、开发框架识别到后期漏洞利用和代码审计
- 3、开发组件识别到后期漏洞利用和代码审计

-
- 1、Web&备案信息&单位名称中发现APP
 - 2、APP资产静态提取&动态抓包&动态调试

解决:

- 1、如何获取到目标APP信息
- 2、如何从APP信息中提取资产

-
- 1、Web&备案信息&单位名称中发现小程序
 - 2、小程序资产静态提取&动态抓包&动态调试

解决:

- 1、如何获取到目标小程序信息
- 2、如何从小程序中提取资产信息

2.详细点



- 1 CMS
- 2 Discuz、WordPress、Ecshop、蝉知等



- 1 前端技术
- 2 HTML5、jquery、bootstrap、Vue等



- 1 开发语言
- 2 PHP、JAVA、Ruby、Python、C#，JS等



- 1 web服务器
- 2 Apache、Nginx、IIS、lighttpd，Apache等



- 1 应用服务器:
- 2 Tomcat、Jboss、Weblogic、Websphere等



- 1 数据库类型:
- 2 Mysql、SqlServer、Oracle、Redis、MongoDB等



- 1 操作系统信息
- 2 Linux、windows等



- 1 应用服务信息:
- 2 FTP、SSH、RDP、SMB、SMTP、LDAP、Rsync等



- 1 CDN信息
- 2 帝联、Cloudflare、网宿、七牛云、阿里云等



- 1 WAF信息
- 2 创宇盾、宝塔、ModSecurity、玄武盾、OpenRASP等。



- 1 蜜罐信息:
- 2 HFish、TeaPot、T-Pot、Glastopf等



- 1 其他组件信息
- 2 fastjson、shiro、log4j、OA办公等

3.演示案例

3.1 小程序获取-各大平台&关键字搜索



- 1 -微信
- 2 -百度
- 3 -支付宝
- 4 -抖音头条

3.2 小程序体验-凡科建站&模版测试上线

```
1  测试: https://qz.fkw.com/
2  参考: https://blog.csdn.net/qq_52445443/article/details/122351865
3  1. 主体结构
4  小程序包含一个描述整体程序的 app 和多个描述各自页面的 page。
5  一个小程序主体部分(即app)由三个文件组成, 必须放在项目的根目录, 如下:
6      文件                必需                作用
7      app.js              是                小程序逻辑
8      app.json            是                小程序公共配置
9      app.wxss            否                小程序公共样式表
10 2. 一个小程序页面由四个文件组成, 分别是:
11     xxx.js              页面逻辑
12     xxx.json            页面配置
13     xxx.wxml            页面结构
14     xxx.wxss            页面样式
15 3. 项目整体目录结构
16     pages                页面文件夹
17     index                首页
18     logs                 日志
19     utils
20     util                 工具类(mina框架自动生成, 你也可以建立一个: api)
21     app.js               入口js(类似于java类中的main方法)、全局js
22     app.json             全局配置文件
23     app.wxss             全局样式文件
24     project.config.json  跟你在详情中勾选的配置一样
25     sitemap.json         用来配置小程序及其页面是否允许被微信索引
```

3.3 小程序抓包-Proxifier&BurpSuite联动

```
1  -对抓到的IP或域名进行web安全测试
2  -对抓到的IP或域名进行API安全测试
3  -对抓到的IP或域名进行端口服务测试
```

3.4 小程序逆向-解包反编译&动态调试&架构



- 1 对源码架构进行分析
- 2 -更多的资产信息
- 3 -敏感的配置信息
- 4 -未授权访问测试
- 5 -源码中的安全问题
- 6
- 7 -小程序多功能组手
- 8 复杂操作: <https://www.cnblogs.com/oodcloud/p/16964878.html>
- 9 简单工具: <http://xcx.siqingw.top/>
- 10 -微信官方开发工具
- 11 <https://developers.weixin.qq.com/miniprogram/dev/devtools/stable.html>